

EXECUTIVE SUMMARY: Policy Review & Compliance Gap Analysis

To: SecureTech Leadership Team

From: GRC Junior Analyst

Date: January 20, 2026

Subject: Comprehensive Review of Compliance Monitoring and Information Security Policies

1. Overview of Policy Frameworks

The current policy landscape at SecureTech aligns with major regulatory frameworks, including **PCI DSS, HIPAA, GDPR, and ISO 27001**.

- **Compliance Monitoring Policy:** Establishes the procedures for semi-annual audits, vendor management, and data privacy (GDPR).
- **Information Security Policy:** Focuses on the CIA Triad (Confidentiality, Integrity, and Availability) through access controls, encryption, and incident response.

2. Key Findings & Identified Risks

Administrative & Quality Control Gaps

- **Documentation Integrity:** Multiple typographical errors and incomplete sentences were identified in the Compliance Monitoring Policy (Sections 2, 4, and 6). These errors suggest a lack of formal version control and can lead to misinterpretation of reporting requirements.
- **Broken Guidelines:** Section 4 of the Information Security Policy contains a misspelling and a broken sentence regarding

employee training, which obscures the actual policy requirement.

Technical & Compliance Risks

- **Delayed Incident Reporting:** The current policy allows **48 hours** for a full incident report. In high-risk environments (HIPAA/PCI), this delay is excessive and may prevent timely containment or regulatory notification.
- **Audit Frequency:** The Risk Register is currently updated **quarterly**. Given the sensitivity of healthcare and financial data, a quarterly cadence may be insufficient to capture emerging threats in a high-velocity environment.
- **Access Control Specificity:** While the policy mentions “need-to-know”, it lacks an explicit mandate for the **Principle of Least Privilege (PoLP)**, which is a requirement for strict ISO 27001 and PCI DSS compliance

3. Recommended Improvements

For the Compliance Monitoring Policy

1. **Increase Risk Register Cadence:** Move from quarterly updates to **monthly reviews**. This ensures that SecureTech remains agile in responding to organizational shifts or new regulatory changes.
2. **Formalize Vendor Audits:** Ensure the “annual compliance audit” for vendors includes a specific “Right to Audit” clause in all contracts to guarantee GDPR and PCI DSS adherence.

For the Information Security Policy

1. **Accelerate Incident Reporting:** Set the “48-hour” window to 24 hours maximum for a preliminary full report to ensure rapid response and forensic integrity.

2. **Enhance Backup Testing:** While backups are daily, the **quarterly testing** should be augmented with automated integrity checks to prevent the “silent failure” of backup systems.
3. **Implement PoLP:** Explicitly define the Principle of Least Privilege alongside RBAC to ensure no user has more access than is required for their specific job function.

4. Conclusion

If these policies are not strictly followed and improved, SecureTech faces significant risks, including **privilege escalation, data breaches, and loss of stakeholder trust**. Furthermore, failure to maintain accurate and professional policy documentation can result in failed external audits for ISO 27001 or PCI DSS certification.